

Secure-by-Design Platform Architecture to Ensure End-User Security

Date: 2025-08-10 UTC

Secure-by-Design Platform Architecture to Ensure End-User Security

Date: 2025-08-10 UTC

One-Pager Summary

Goal Deliver a production-grade platform where security and privacy are first-class, protecting end users from account takeover, data leakage, supply-chain risk, and abuse. The system must be resilient, observable, and compliant, with defense-in-depth and zero-trust principles, while meeting strict SLOs.

Key Outcomes

Strong identity and session security with phishing-resistant MFA and adaptive risk controls. End-to-end encryption in transit and at rest with least-privilege access and continuous verification. Hardening against common classes of attacks (injection, SSRF, XSS, CSRF, credential stuffing, API abuse). Proactive privacy controls and data minimization, with auditability and rapid incident response. Secure SDLC and supply chain with signed builds, SBOMs, and verified deployments.

Primary Assumptions

Multi-region deployment, millions of MAU, peak thousands of requests per second per region. Web, iOS, Android clients; public REST and WebSocket APIs. Regulatory scope includes SOC 2 Type 2, GDPR, CCPA; possible regional data residency. Integration with third-party IdP, payment processor, and analytics (privacy-preserving).

Functional Requirements

Identity and Access Phishing-resistant MFA, passkeys, device binding, session management with rotation and revocation. Role- and attribute-based authorization with fine-grained policies (OPA). Secrets and Keys Centralized KMS/HSM, envelope encryption, periodic rotation, scoped service credentials. Data Protection Field-level encryption for sensitive PII, tokenization option, privacy-by-default collection and retention. Threat Protection WAF, RASP, bot mitigation, per-user and per-IP rate limits, anomaly detection, abuse reporting. Integrity and Supply Chain Signed artifacts, SBOMs, dependency scanning, provenance attestation. Observability and IR Tamper-evident audit logs, SIEM, SOAR playbooks, security runbooks, post-incident review. Compliance and Rights Consent capture, data subject access/export/delete, purpose limitation, residency controls. Tenant Controls Per-tenant keys, quotas, rate limits, and policy overrides; optional hard isolation.

Non-Functional Requirements

Availability 99.95% for auth and read APIs; 99.9% for writes/admin. Latency p95: login 300 ms, token mint 120 ms, typical API < 150 ms, policy check < 10 ms. Durability RPO 0 for accepted writes to core auth and audit stores; RTO < 15 min regional. Scalability linear via stateless services, sharded caches/stores; cost-aware autoscaling. Security posture continuously validated with automated controls and evidence capture.

Architecture Overview

Zero-Trust Cell Per-region cell with independent blast radius: Edge (CDN/WAF), API Gateway, AuthN/AuthZ, Policy (OPA), Services, Secrets/KMS, Data stores, Observability, SIEM/SOAR. Thin global control plane for config, identity federation, and fleet keys. Edge and Gateway CDN + WAF + Bot manager terminate TLS 1.3, enforce HSTS, CSP, COOP/COEP, and rate limits. API Gateway verifies tokens, mints DPoP/MTLS-bound tokens where applicable, and normalizes headers. Identity External IdP or in-house IdP with WebAuthn/passkeys, OAuth 2.1/OIDC, refresh-token rotation,

session binding to device posture. Token service uses asymmetric keys (JWKS) with short TTLs. Service Mesh mTLS between services; SPIFFE IDs; L7 authz via OPA sidecars. Least privilege enforced at the mesh and datastore layers. Data Protection KMS/HSM-backed envelope keys; per-tenant DEKs. Field-level encryption for sensitive PII; deterministic tokens for joins where needed. Client-side encryption optional for high-sensitivity flows. Abuse and Threat Pipeline Real-time signals from edge and apps into Kafka; Flink evaluates heuristics/ML for bots, credential stuffing, and fraud. Dynamic risk scores feed the policy engine. Privacy and Residency Data tagged with purpose, region, tenant. Residency router ensures

writes land in allowed regions; cross-region analytics uses anonymized aggregates. Observability and IR Tamper-evident audit logs, immutable storage for security events, SIEM correlation, SOAR runbooks for containment (token revocation, key rotation, WAF rules).

Data Flow Login Client → Edge/WAF → IdP → Token Service (JWKS-signed) → Session Store (revocation list) → Client; device-bound tokens for stronger protection. API Request Client → Edge (bot/rate checks) → Gateway (JWT/MTLS/DPoP validation) → OPA policy decision → Service → Data access via scoped IAM + KMS; audit trail emitted. Sensitive Write Policy engine evaluates risk score; requires step-up MFA if high risk; envelope encryption applied; append-only audit log written. Security Event Signals → Kafka → Stream rules/ML → SOAR action (e.g., throttle IP range, revoke sessions, push CAPTCHAs).

Technology Stack (reference) Edge: Cloud CDN, WAF, Bot Manager, TLS 1.3 with ALPN (HTTP/2, HTTP/3). Auth: OIDC provider, WebAuthn/passkeys, OAuth 2.1, JWT/JWKS, DPoP, MTLS, device posture attestation (where supported). Policy & Mesh: OPA/Gatekeeper, SPIFFE/SPIRE for workload identity, service mesh mTLS. Secrets & Keys: Cloud KMS/HSM, Vault for app secrets, age or PGP for ops. Data: Postgres/Aurora for auth and policy; DynamoDB/Spanner/Scylla for session/consent; Redis for tokens/nonce/ratelimit; S3/GCS + Iceberg/Delta for logs and archives. Pipelines: Kafka/Kinesis, Flink/Spark for threat analytics. Observability: OpenTelemetry, Prometheus/Grafana, Loki, Jaeger; SIEM (e.g., Splunk/Elastic), SOAR. CI/CD: GitHub/GitLab, SAST/DAST/IAST, SLSA Level targets, Sigstore (cosign), Argo CD/Rollouts, Terraform/Pulumi, OPA Conftest.

Storage Strategy

Hot Redis for token introspection cache, nonce, rate limits, and session shard. Low TTL and eviction-aware design. Warm Postgres/Aurora for auth, policy, and audit indices; DynamoDB/Scylla for high-QPS sessions and consents. Cold Object storage for encrypted logs and evidence (Parquet with Iceberg/Delta). Immutable vault for audit trails via WORM policies. Indexing Use resource- and subject-centric indexes for fast policy decisions; GIN/JSONB for attributes with quotas to prevent unbounded growth.

Scaling Approach Stateless gateways and auth services behind autoscalers; partition by tenant/region. Redis and session stores sharded by tenant+user hash; avoid hot keys via token and nonce hashing. Policy engines co-located; cache decisions with short TTL; push invalidations on policy changes. KMS scales via envelope encryption; rotate DEKs without re-encrypting payloads.

Latency Budgets & SLAs Edge/WAF checks < 15 ms p95. JWT/DPoP/MTLS verification < 10 ms p95. OPA policy decision < 10 ms p95. Session lookup/cache < 5 ms p95. Token minting < 120 ms p95. Typical API end-to-end < 150 ms p95. Availability: 99.95% read; 99.9% write/admin.

Key Algorithms & Workflows Adaptive Auth Risk scoring from IP reputation, velocity, device posture, impossible travel; step-up MFA when risk exceeds threshold. Rate Limiting Token bucket per user, per IP ASN, per tenant; global circuit breakers on anomalies. Secrets & Key Rotation Automated rotation with dual-read period; envelope keys (DEK) rotated under KEK; cryptographic agility. Consent & Data Minimization Collect only necessary fields; TTL-based deletion; purpose-bound access enforced in OPA.

Tamper-Evident Audit Hash-chain or Merkle-tree of audit events; periodic anchoring to external timestamping service. Abuse Response SOAR playbooks execute: revoke sessions, block IP ranges, rotate keys, add bot challenges, notify on-call.

Data Models

User user id pseudonymous, primary key refs (kept in vault if needed), email hash, passkey

public key, mfa methods, risk flags, created/updated. Session session id, user id, device id, issued at, expires at, refresh token hash, token binding, ip asn, user agent hash, revocation state. Consent user id, purpose id, scope, granted at, expires at, region. Policy policy id, effect allow/deny, subjects roles/attributes, resources, actions, conditions, version. AuditEvent event id, actor, target, action, attributes, ip, asn, user agent hash, result, signature, logged at. RiskEvent subject user/session/device/ip, signals, model score, reason codes, action taken, created at. KeyMaterial key id, tenant id, purpose, wrapper key ref, rotation schedule, status, created at.

Security, Reliability, and Compliance

Defense-in-depth: WAF, RASP, CSP, sandboxing, SSRF egress policies, parameterized queries, prepared statements. Privacy: user rights APIs for access/export/delete; row/column policies; tokenization for analytics. Reliability: multi-AZ per cell, active-active across regions for stateless tiers; warm-standby for stateful stores; chaos and DR drills. Compliance: evidence collection (controls, logs), vendor due diligence, DPA, subprocessor registry, access reviews, quarterly key rotations.

Multi-Tenancy

Tenant id present in every key and token; per-tenant KMS keys and quotas. Logical isolation via namespaces and network segmentation; optional dedicated cells/VPCs for premium tenants. Tenant-scoped WAF rules, rate limits, policies, and analytics dashboards.

CI/CD & Supply Chain IaC for everything; ephemeral envs per PR. SLSA-aligned pipeline:

SAST/DAST/IAST, dependency allowlist, SBOM generation, image signing (cosign), verified provenance, policy-as-code gates. Progressive delivery with Argo Rollouts, automatic rollback on SLO burn; database migrations with online DDL and feature flags.

APIs & Integration Points Auth POST login, POST mfa, POST refresh, POST revoke. Tokens GET jwks.json, POST token exchange, POST introspect. Policy POST evaluate, GET policies, PATCH policies, GET decision logs. Security Signals POST risk event, POST abuse report. Privacy POST request export, POST request delete, GET request status. Admin POST rotate key, POST quarantine ip or device, GET audit events, POST tenant config.

Observability & Operations OpenTelemetry traces, metrics, logs with PII scrubbing; SIEM correlation rules. Golden dashboards: auth success rate, failed logins, risk-trigger rate, policy decision latency, token mint latency, p95/p99 API, error budget burn. SLO-aware autoscaling; budgets and anomaly detectors for sudden auth spikes. Runbooks for incident classes: ATO surge, token replay, key compromise, WAF false positives, regional failover.

Capacity Planning & Cost Estimate Reference region with 5k-50k RPS auth/API traffic, 1-5M MAU.

Gateways: modest CPU-bound; autoscale on p95 latency. Redis: 6-12 shards; keep < 65% memory; ops/second headroom 2x peak. Auth DB: primary + 2-3 replicas; tune for short, indexed queries. Object storage logs grow with retention; lifecycle policies to control cost. Rough monthly cost per busy region: 25k-80k depending on auth volume and retention.

Testing Strategy & Failure Drills Security tests: SAST/DAST/IAST, fuzzers, dependency scans, secrets scanners, container CIS benchmarks. Functional: unit, contract tests for tokens/policies, replay/idempotency tests. Load/soak: auth bursts, policy spikes, cache churn; resilience to partial outages (WAF, KMS throttling). Chaos: revoke JWKS key mid-flight, Redis shard loss, DB failover, regional failover. IR: tabletops and live drills for ATO, data breach, key compromise; RTO/RPO validation.

Phased Build Plan

MVP 3 months Single-region cell, OIDC login with passkeys and TOTP fallback, JWT issuance, Redis session cache, WAF and rate limits, audit logs, basic SIEM. Phase 2 6-9 months Multi-region cells, OPA policy engine, SOAR automation, consent APIs, per-tenant keys, device posture signals, anomaly detection. Phase 3 12 months Supply-chain hardening to SLSA targets, DPoP/MTLS token binding, privacy vault, advanced risk models, dedicated cells for premium tenants, tighter SLOs. Key Choices, Trade-Offs, Risks, Mitigations Trade: Stronger security adds latency; mitigate with edge checks, caching, and short tokens. Trade: Per-tenant keys and isolation increase ops cost; offer tiered options. Risk: Key compromise; mitigate with HSM-backed keys, rotation, and blast-radius-limiting design.

Risk: ATO and bot surges; mitigate with adaptive auth, rate limits, and SOAR playbooks. Risk: Privacy breaches; mitigate with tokenization, field encryption, and minimization with strict retention.